

ASSIGNMENT: Module 3 – Report: Asset Inventory and Lifecycle Risk Case Study

The 2017 Equifax breach exposed the personally identifiable information (PII) of at least 145.5 million individuals and demonstrated how weaknesses in asset inventory, data classification, and lifecycle governance can create systemic risk. Drawing on the GAO's investigation (U.S. Government Accountability Office [GAO], 2018), breach analyses (BreachSense, n.d.), and course materials, this report outlines Equifax's failures, proposes an improved asset inventory strategy, and identifies controls that could have reduced the breach's impact.

Equifax's Failures in Asset Inventory and Classification

The breach resulted from interconnected failures in visibility, governance, and data protection.

A key failure was Equifax's inability to track and patch systems running Apache Struts.

Although a patch was available, the internal distribution list used to notify responsible teams was outdated, so critical personnel never received the alert (GAO, 2018). This indicates that Equifax lacked an authoritative inventory of systems and did not maintain reliable communication channels tied to operational roles.

Equifax also allowed a critical SSL certificate on its traffic inspection device to expire for more than six months. Because the certificate was expired, the monitoring system could not decrypt outbound traffic, allowing attackers to exfiltrate data for 76 days without detection (BreachSense, n.d.). This reflects a failure in certificate lifecycle management—an essential component of asset tracking.

Once inside the dispute portal, attackers were able to move laterally to 51 databases containing highly sensitive PII. The GAO report notes that Equifax lacked adequate network segmentation and data governance, allowing a low-sensitivity web application to access high-sensitivity data

stores (GAO, 2018). Sensitive attributes such as SSNs, birthdates, and addresses were stored together, making the data immediately usable once accessed.

Finally, Equifax failed to classify PII according to its sensitivity. Under modern frameworks, the compromised data would be considered “Restricted” or “Regulated,” requiring strict access controls and monitoring. Instead, it was treated as standard operational data, with insufficient protections applied.

Improved Asset Inventory Strategy

The breach resulted from interconnected failures in visibility, governance, and data protection.

A key failure was Equifax’s inability to track and patch systems running Apache Struts.

Although a patch was available, the internal distribution list used to notify responsible teams was outdated, so critical personnel never received the alert (GAO, 2018). This indicates that Equifax lacked an authoritative inventory of systems and did not maintain reliable communication channels tied to operational roles.

Equifax also allowed a critical SSL certificate on its traffic inspection device to expire for more than six months. Because the certificate was expired, the monitoring system could not decrypt outbound traffic, allowing attackers to exfiltrate data for 76 days without detection (BreachSense, n.d.). This reflects a failure in certificate lifecycle management—an essential component of asset tracking.

Once inside the dispute portal, attackers were able to move laterally to 51 databases containing highly sensitive PII. The GAO report notes that Equifax lacked adequate network segmentation and data governance, allowing a low-sensitivity web application to access high-sensitivity data stores (GAO, 2018). Sensitive attributes such as SSNs, birthdates, and addresses were stored together, making the data immediately usable once accessed.

Finally, Equifax failed to classify PII according to its sensitivity. Under modern frameworks, the compromised data would be considered “Restricted” or “Regulated,” requiring strict access controls and monitoring. Instead, it was treated as standard operational data, with insufficient protections applied.

Controls That Could Have Reduced Breach Impact

Network and Data Segmentation Segmentation limits lateral movement and reduces breach impact. Equifax should have isolated the dispute portal in a DMZ and restricted its access to backend databases through least-privilege APIs. At the data layer, sensitive identifiers such as SSNs should be stored in separate encrypted vaults and referenced via surrogate keys, preventing attackers from reconstructing full identity profiles.

Patch Management Enforcement Automated patch deployment and verification would have ensured timely remediation of the Apache Struts vulnerability. Patch management should be tied to the CMDB so that systems running vulnerable components are automatically flagged and prioritized.

Disaster Recovery and Incident Response Exercises Semiannual disaster recovery and incident response tabletop exercises would validate monitoring capabilities, communication pathways, certificate dependencies, and role-based responsibilities. Quarterly reviews of certificates, access roles, and operational processes would have identified the expired SSL certificate long before attackers exploited it.

Conclusion

The Equifax breach illustrates how failures in asset inventory, classification, and lifecycle governance can create systemic vulnerabilities that attackers exploit with devastating consequences. A modern asset inventory strategy—supported by automated discovery, certificate

lifecycle management, data classification, and role-based governance—would have provided the visibility needed to prevent or detect the breach. Combined with strong controls such as segmentation, patch management, and regular disaster recovery exercises, these measures form a defense-in-depth approach capable of protecting high-value data assets throughout their lifecycle.

References

BreachSense. (n.d.). *Equifax data breach explained: A case study*.
<https://www.breachsense.com/blog/equifax-data-breach/>

Sawant, A. (2025). *Module 3: Data classification and protection* [Unpublished course document]. Northeastern University.

Sawant, A. (2025). *Module 3: Data classification and protection—Coursera readings* [Unpublished course document]. Northeastern University.

U.S. Government Accountability Office. (2018). *Data protection: Actions taken by Equifax and federal agencies in response to the 2017 breach (GAO-18-559)*.
<https://www.warren.senate.gov/imo/media/doc/2018.09.06%20GAO%20Equifax%20report.pdf>

Methodology

Portions of this assignment were developed with assistance from Microsoft Copilot to support organization, clarity, and alignment with APA style. Copilot was used to help structure the analysis, refine wording, and ensure accurate representation of technical concepts related to asset inventory, data classification, and security controls. All AI-generated content was reviewed, edited, and validated by the author to ensure accuracy, relevance, and compliance with Northeastern University's Academic Integrity and Use of AI policy. The final submission reflects the author's own understanding, judgment, and academic work.